

Projeto Auditoria nstech

Plano de Ação - Pendências e Próximos Passos

Situação Atual (Branch revisao_codex)

Revisamos as implementações mais recentes no branch atual. Verificamos que avanços importantes foram concluídos, como a implementação de soft-delete para descartes de auditoria e liberação de cotas, ajuste nas datas baseadas no áudio, regras determinísticas para zeramento de notas e refatoração da automação do backend para lidar com limitação de falhas assíncronas.

Ações Prioritárias Pendentes

1. Segurança e Infraestrutura (Prioridade Crítica)

- Rotacionar senhas e chaves de APIs: Azure OpenAI, Serviços Cognitivos, PostgreSQL (Neon) e Service Accounts do GCP.
- Higienização do histórico (Git History): Limpar commits antigos para evitar exposição cruzada de segredos previamente submetidos.
- Implementação de Cofre de Senhas: Integrar Azure Key Vault ou Google Secret Manager em substituição às variáveis estáticas.

2. Frontend e Estabilidade do Usuário (Curto Prazo)

- Uso de AbortController no React: Prevenir race conditions e requests persistentes ao trocar rapidamente de telas (useAuditFlow).
- Limpeza de Intervalos: Garantir que processamentos em lote no cliente (progressInterval) sejam devidamente cancelados caso o componente seja fechado.
- Remoção de Credenciais do React State: Não armazenar o estado das senhas via text state, migrando sua gestão para referências voláteis após a submissão.
- Upload Inteligente: Implementar validação e bloqueio client-side para o tamanho máximo e tipos dos arquivos de áudio suportados.

3. Melhorias de Arquitetura e Negócios (Médio a Longo Prazo)

- Proteções de Requisição Global: Incluir verificações CSRF no FastAPI em todas as requisições de configuração.
- Automação Huawei Integrada: Construir a integração em backend (API ou Playwright) para download padronizado dos áudios dos servidores Huawei on-premise/cloud.
- Dívida Técnica Estática: Reduzir a carga de +14.000 warnings gerados por regras não conformes do ESLint no framework Next/React do projeto.
- Observabilidade em Nuvem: Transformar logs em texto simples com tamanhos elevados para logs estruturados (JSON) e adicionar Sentry/Prometheus para facilitar o monitoramento nativo.

Conclusão

Recomendamos aprovar a continuidade imediata para as frentes de Segurança (higienização de chaves) seguidas da estabilização e adequação do fluxo do frontend para evitar consumo imprevisto de tokens das APIs. Assim que os gaps principais de segurança forem supridos, sugere-se alocar esforço para o pipeline da automação com a Huawei.